CARD: weighted scoring and presentation defence

1. Published basis and what changed

Applies to **weighted-v3**, prepared for the 6 October 2026 presentation. Black-and-white text only. Use a fresh replay: older saved records retain their earlier scoring model.

Main reference [1]: Nusrat Zahan, Parth Kanakiya, Brian Hambleton, Shohanuzzaman Shohan and Laurie Williams, "OpenSSF Scorecard: On the Path Toward Ecosystem-Wide Automated Security Metrics," IEEE Security & Privacy, volume 21, issue 6, pages 76-88, 2023. DOI: **10.1109/MSEC.2023.3279773**.

Exact location: Section II, "OpenSSF Scorecard," explicitly lists severity weights Low 2.5, Medium 5, High 7.5 and Critical 10, and describes a weighted average of individual checks. Table I lists the repository security metrics.

Open manuscript: https://arxiv.org/html/2208.03412v3#S2. Publisher record: https://doi.org/10.1109/MSEC.2023.3279773. The publisher version may require institutional access; the author manuscript is open.

Severity is different from a contribution

CARD expresses the published ratios as raw severity ratings **25, 50, 75 and 100**. The unit conversion preserves 1:2:3:4. A raw rating is then weighted against the entire declared assessment capacity. It is not added directly to the final score.

In v3, the previous clipped sum is replaced by a **normalized weighted average**. The applicable weights total one (100%). Each group uses a rating between zero and one. Therefore the final score stays within 0-100 naturally, without discarding excess points.

Example: raw severities 75 and 50 for ops-mirror become contributions **30 and 20**, totaling **50/100**. Remaining applicable groups contribute zero. Page 3 shows the full derivation.

What is sourced and what is adapted

The IEEE research supplies the severity ratios and weighted-average mathematical form. CARD defines its own evidence groups and their ranges using the highest supported detector severity. The signal classifications, grouping and policy thresholds are our documented adaptations.

The paper does not train an agent-request classifier, provide measured attack probabilities for our signals or validate CARD. This is a reproducible, literature-based index awaiting expert review and benchmark calibration. Scorecard's own check score measures security practice, with higher being better; CARD measures matched concerns, with higher being worse.

2. Why each raw severity is assigned

Rubric: Low is uncertain or non-specific evidence. Medium is a stronger identity, authority, transport or linkage concern. High is an explicit unavailable-artifact report or a concrete execution/override pattern. No current detector assigns Critical; the scale reserves it for future independently confirmed threats. These grades are judgements to validate, not fitted coefficients.

Identity and provenance

Reported missing: High, 75. The artifact cannot be used as identified if unavailable. Spracklen et al., USENIX Security 2025 [2], documents the hallucinated-package attack surface. CARD receives a caller report rather than verifying a registry. High expresses concern strength, not a 75% attack probability.

Unknown existence: Low, 25. Absent evidence is weaker than a report of nonexistence. Treating both the same would erase this distinction.

Package lookalike: Medium, 50. Ohm et al., DIMVA 2020 [3], describes typosquatting. Similar names can also be legitimate. Our small catalog and name-matching boundary are prototype choices.

Reported unsigned: Low, 25. Signed provenance matters in [1]. Its actual Signed-Releases check is High. We intentionally grade an unverified caller boolean lower because it is weaker evidence than examining actual releases. This is an adaptation.

Capabilities and static content

General capability: Low, 25. Network/filesystem access can be legitimate. **Secrets, shell or process spawning: Medium, 50.** These expose sensitive information or execution authority. Least-privilege guidance [6] motivates scrutiny; it does not prescribe these grades. Permission duplicates do not increase severity.

Encoding/obfuscation or credential-location marker: Low, 25. Research [3,4] motivates inspecting code, but encoding and process.env also appear in benign programs. A marker does not establish exfiltration.

Remote download piped to shell: High, 75. The pattern can execute unreviewed code, a mechanism relevant to [3]. Legitimate installers may also use it. **Instruction override in skill/MCP text: High, 75.** ACM AISec research [5] supports scrutiny of instruction-bearing content. A literal match is not a demonstrated successful attack.

Other inputs

Non-HTTPS, private/local host and invalid URL: Medium 50, motivated by transport/destination guidance [7,8]. Their decision follows the combined-score policy. Generic earlier non-allowed activity: Low 25; a shared name across types: Medium 50. Context uplift is a project hypothesis. **Age/downloads: no fixed penalty** because no transferable 7-day/50-download cutoff was found.

3. A fixed 100-point budget

Package, skill and MCP profile

Identity & provenance: maximum severity 75, weight 75/250 = **30%**.

Requested capabilities: maximum severity 50, weight 50/250 = **20%**.

Static content: maximum severity 75, weight 75/250 = **30%**.

Session context: maximum severity 50, weight 50/250 = **20%**.

Maximum raw capacity is **75 + 50 + 75 + 50 = 250**. The weights are **30% + 20% + 30% + 20% = 100%**. Each maximum comes from the highest declared detector severity in that group, avoiding additional independently chosen percentages. Range selection remains our adaptation.

For each group, take its strongest matched severity S, or zero. Divide by its declared maximum C to get a group rating between zero and one. Multiply that rating by the group's weight and by 100.

```
weight = group maximum / total applicable capacity

rating = strongest matched severity / group maximum

contribution = 100 x weight x rating

score = sum(contributions)

= 100 x sum(matched group severities) / total capacity
```

Your ops-mirror example

Missing: severity 75; rating 75/75 = 1; weight 30%. Contribution **100 x 0.30 x 1 = 30**.

Sensitive capability: severity 50; rating 50/50 = 1; weight 20%. Contribution **100 x 0.20 x 1 = 20**.

Content and context: no matched concern, contributing zero. Unsigned is weaker than missing in the same provenance group, so it adds nothing. **30 + 20 + 0 + 0 = 50/100**. Equivalent: **125/250 x 100 = 50**. Maximum case: **250/250 x 100 = 100**. No clipping.

URLs and rounding

URLs add transport capacity 50, making total capacity **300**. The weights are 1/4, 1/6, 1/4, 1/6, 1/6, which sum to one. Non-URL source labels are not parsed by the URL detector, so that group is inapplicable to them.

All applicable groups remain in the denominator, even unmatched ones. Disabling correlation does not reduce the capacity. Related cues use the strongest within a group. Two-decimal contributions are rounded together so the displayed parts equal the total; a one-cent rounding adjustment may occur for URLs.

4. Demonstration and panel questions

Current outcomes: review 20, deny 50

Known publisher: **0, Allow**. This is not independent safety certification.

New evaluation / Young integration: provenance severity max(unknown 25, unsigned 25) = 25, network severity 25. Each contributes 25/250 x 100 = 10. **10 + 10 = 20, Needs review**. Age 6 and downloads 18 add nothing.

Linked trust signals: URL severities 75 + 50 + 25 = 150 out of 300. Weighted **25 + 16.67 + 8.33 = 50, Deny**. Later skill severities 25 provenance + 50 context = 75 out of 250. Weighted **10 + 20 = 30, Needs review**. Correlation off: skill **10, Allow**.

Over-privileged unknown source: missing 75 plus sensitive capability 50, out of capacity 250. Weighted **30 + 20 = 50, Deny**. Its current text does not match the narrow instruction-override pattern; describe actual matched evidence.

Likely questions

Why not add 75 and 50 directly? Those are raw severity ratings on different group ranges. The weighted calculation gives them shares of a declared total budget. Their weighted contributions are 30 and 20.

Why divide by 250, not 125? The assessment has four groups with total possible capacity 250. Dividing only by matched capacity would inflate sparse findings; the denominator is fixed before matching. Unmatched groups contribute zero.

Why does the score never exceed 100? Group ratings are in [0,1] and weights sum to one. A weighted average of those ratings is in [0,1]; scaling by 100 preserves the bound.

Why review 20 and deny 50? Review 20 catches a medium concern in the four-group profile or two low concerns. Deny 50 means half the possible concern budget is occupied. These are operational choices, not empirically optimal boundaries. A single medium URL concern is 16.67; stricter URL deployments need a lower threshold or additional mandatory controls.

Did the papers validate your entire model? No. We adopt the published scale and mathematical method; group/range/classification choices are documented hypotheses. Future work uses expert-reviewed labels, separate calibration/test data, detection and false-positive measurements, threshold sensitivity, correlation ablation and baseline comparisons.

What do the tests prove? All supported severity combinations stay bounded and their displayed contributions add up. Tests also cover UI controls, persistence and legacy compatibility. They do not establish detection accuracy.

5. References and a short speaking script

Peer-reviewed IEEE article supplying the scale and method

[1] N. Zahan et al., "OpenSSF Scorecard: On the Path Toward Ecosystem-Wide Automated Security Metrics," IEEE Security & Privacy, 21(6), 76-88, 2023. DOI: **10.1109/MSEC.2023.3279773**. See Section II and Table I. https://arxiv.org/html/2208.03412v3#S2

Security conference research motivating signals

[2] J. Spracklen et al., "We Have a Package for You! A Comprehensive Analysis of Package Hallucinations by Code Generating LLMs," USENIX Security, 2025. https://www.usenix.org/conference/usenixsecurity25/presentation/spracklen

[3] M. Ohm, H. Plate, A. Sykosch, M. Meier, "Backstabber's Knife Collection: A Review of Open Source Software Supply Chain Attacks," DIMVA, pp. 23-43, 2020. DOI: **10.1007/978-3-030-52683-2_2**. https://arxiv.org/abs/2005.09535

[4] A. Sejfia, M. Schafer, "Practical Automated Detection of Malicious npm Packages," ACM/IEEE ICSE, pp. 1681-1692, 2022. DOI: **10.1145/3510003.3510104**. https://arxiv.org/abs/2202.13953

[5] S. Abdelnabi et al., "Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection," ACM AISec, pp. 79-90, 2023. DOI: **10.1145/3605764.3623985**. https://arxiv.org/abs/2302.12173

Additional engineering guidance (not research papers)

[6] OWASP AI Agent Security: least privilege and monitoring. https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html

[7] OWASP SSRF Prevention: destination validation and network boundaries. https://cheatsheetseries.owasp.org/cheatsheets/Server_Side_Request_Forgery_Prevention_Cheat_Sheet.html

[8] MITRE CWE-319: cleartext-transmission risk. https://cwe.mitre.org/data/definitions/319.html

Suggested presentation wording

"We use a severity scale and weighted-average method described in peer-reviewed IEEE research. Our applicable group ranges produce weights totaling 100%. A raw severity of 75 is not 75 additive points: its weighted share here is 30. The displayed contributions add exactly to the total. We document our adaptations and will validate detection accuracy using labelled workflows."

Method and sources checked 6 October 2026. Complete rules: docs/SCORING.md. Implementation: shared/scoring.ts and server/engine.ts. A citation supports the stated method or concern; it is not an endorsement of CARD.